

Web Server and Application Security

Burp Suite Intruder/Repeater



1. For ease of conducting the session, we have disabled your microphones. Do keep your video turned on at all times.
2. Please raise any questions you may have through the chat.
3. Please confirm if you can see the presentation and the presenter clearly.
4. This is a 120-min long session. As we go through the session, I will take questions at the end of each concept and at the end of the session.
5. I will unmute the audio of participants volunteering for any activity.

Thus far, in the last topic you've learned about:

- Burp
- Nikto
- CMSEEK
- Wpscan



In today's session, you will learn about:

- Burp Suite Repeater
- Burp Suite Intruder
- Burp Suite Decoder
- Burp Suite Comparer



Source: Freepik

What is Burp Repeater?



Created by fae frey
from Noun Project

- Select an HTTP message anywhere in Burp, and choose "Send to Repeater" from the context menu
- This creates a new request tab in Repeater, and automatically populate the target details
- For HTTP messages, each Repeater tab contains:

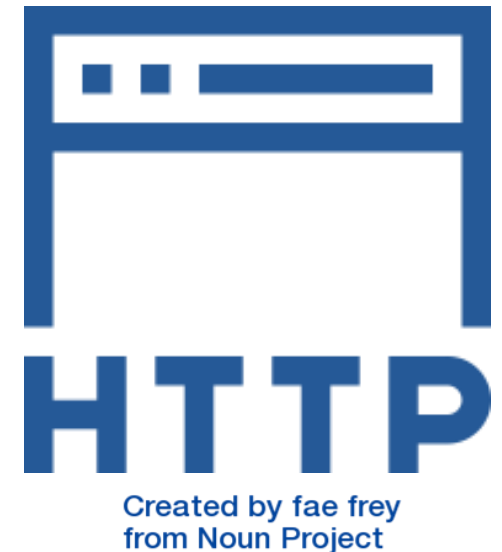
Controls to issue requests and navigate the request history

The target server to which the request will be sent is shown

An HTTP message editor containing the request to be issued

An HTTP message editor showing the response that was received

- Each Repeater tab maintains its own history of the requests that have been made within it
- You can click the "<" and ">" buttons to navigate backwards and forwards through the history
- You can also use the drop-down buttons to show a numbered list of adjacent items in the history
- At any point in the history, you can edit and reissue the currently displayed request



- To use Burp Repeater with WebSocket messages, you can select a WebSocket message in the Proxy history, and choose "Send to Repeater" from the context menu
- For WebSocket messages, each Repeater tab contains:

A message editor containing the WebSocket message that will be sent

The WebSocket connection via which the message will be sent

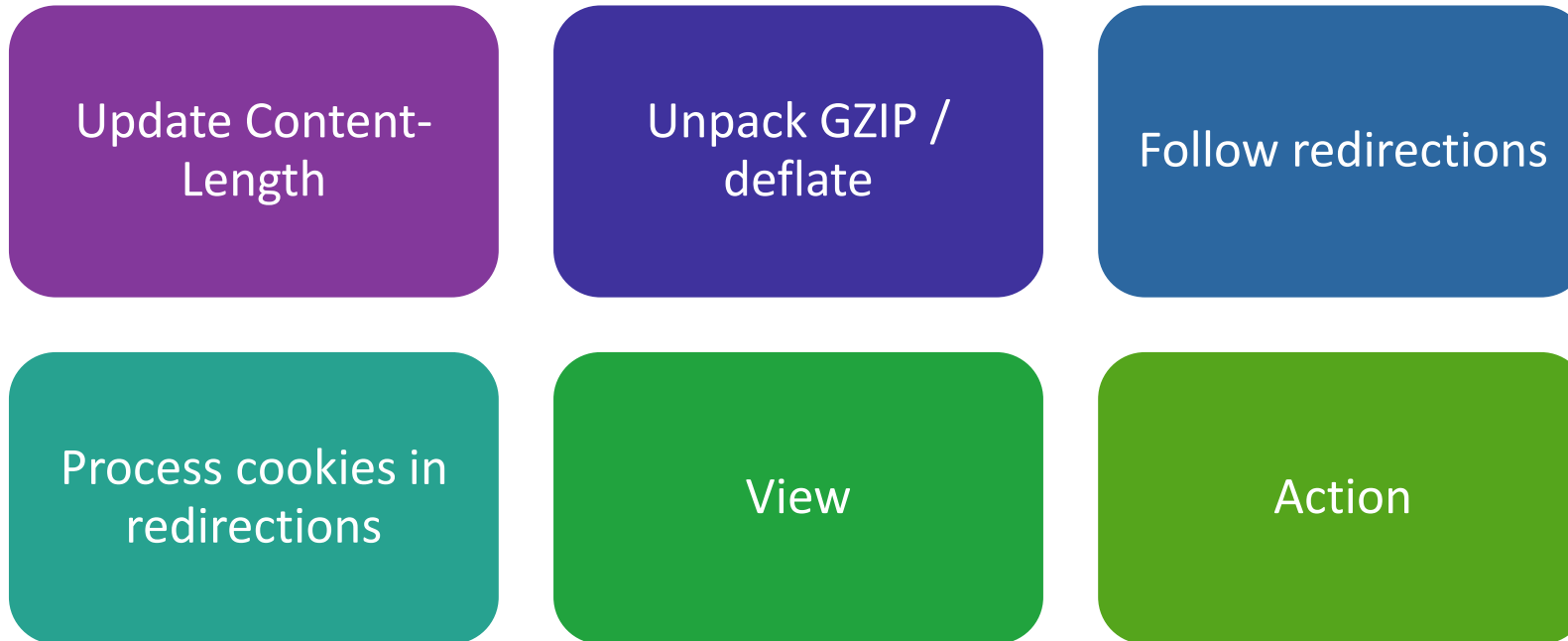
A history table showing all of the messages that have been sent and received

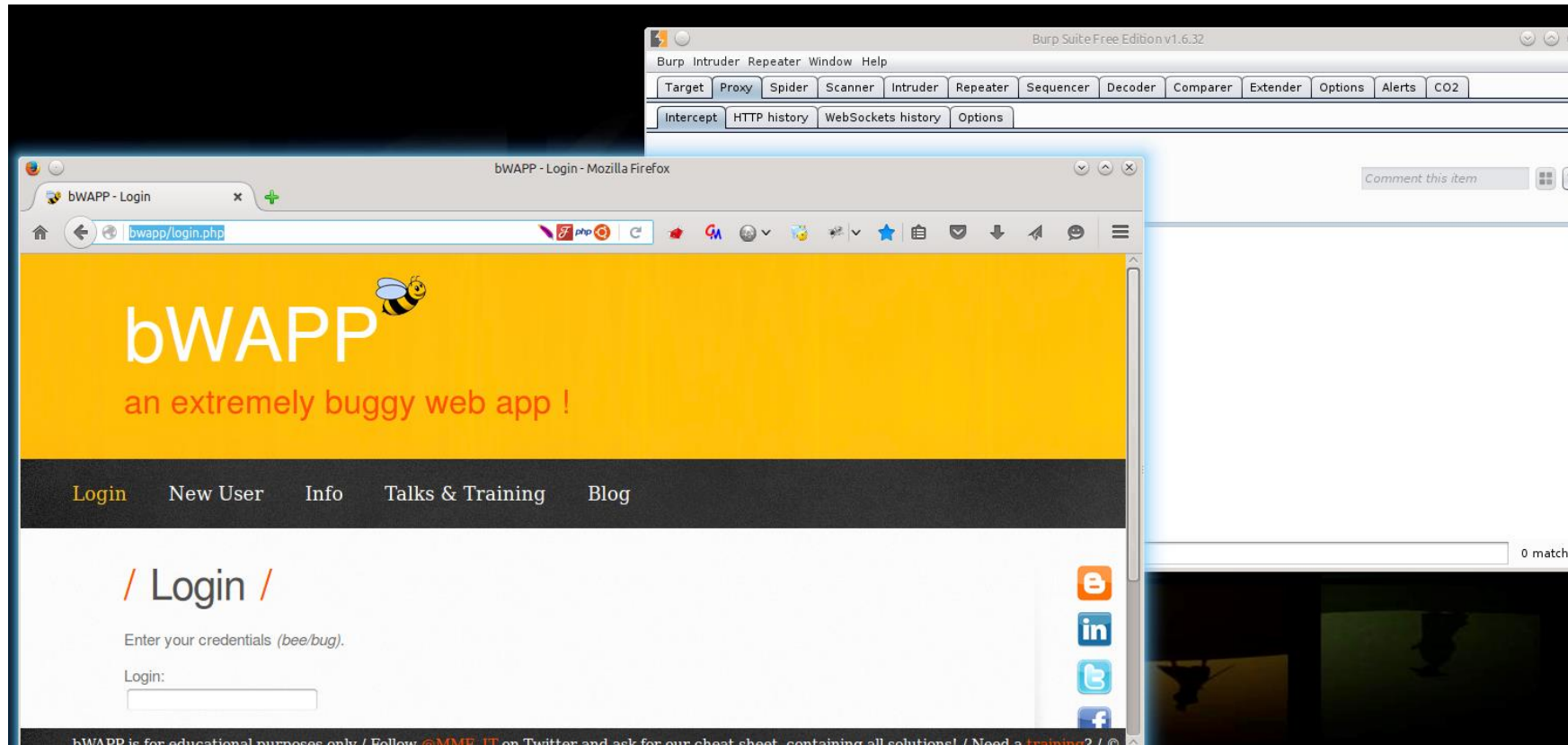
- You can edit the message that will be sent, and select whether it should be sent to the server or client
- The option to send a message to the client is only available in connections that are still open via Burp Proxy
- When your message is ready to send, click the "Send" button to send the message
- Optionally, the history table will automatically select the next message that is received after you sent the message

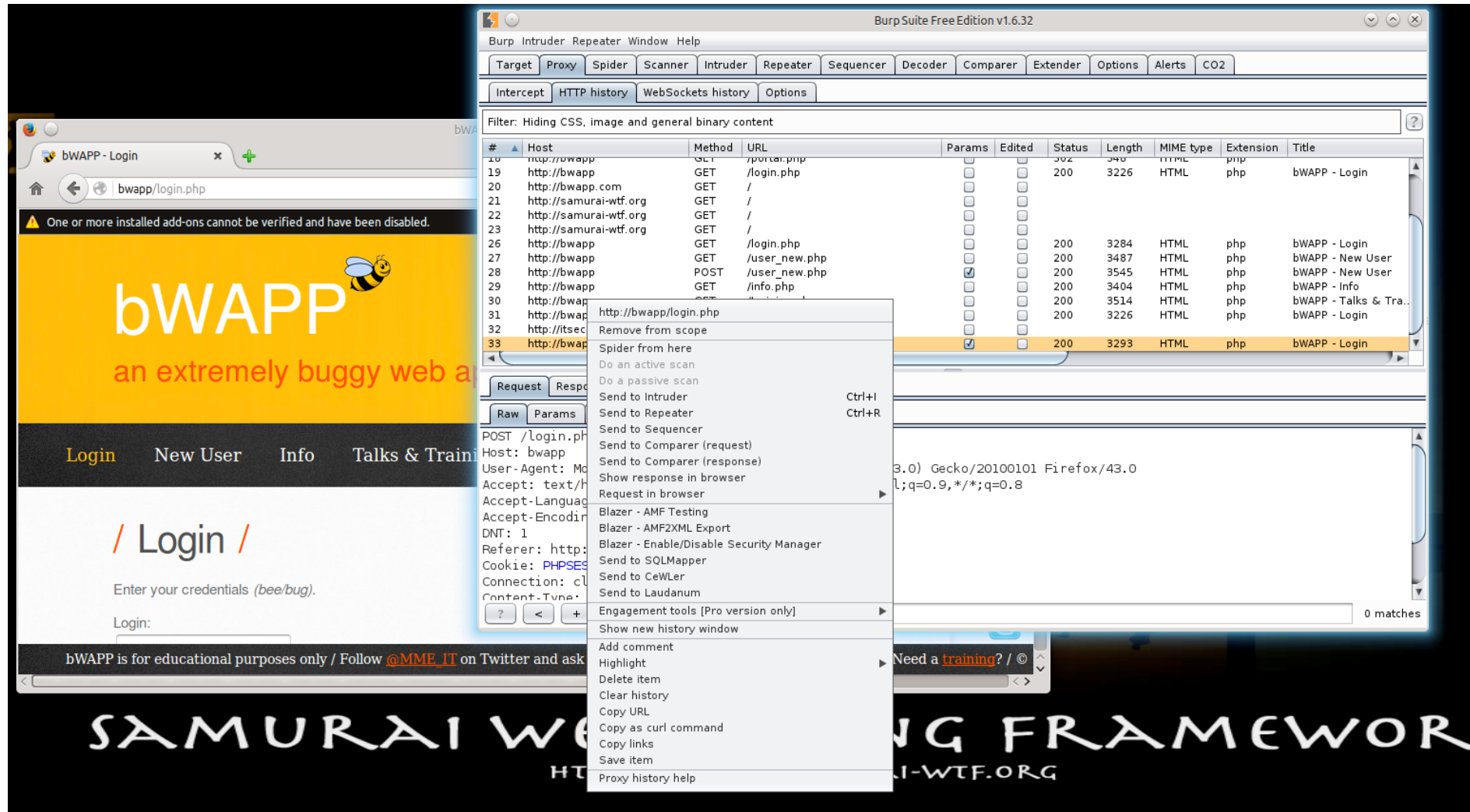


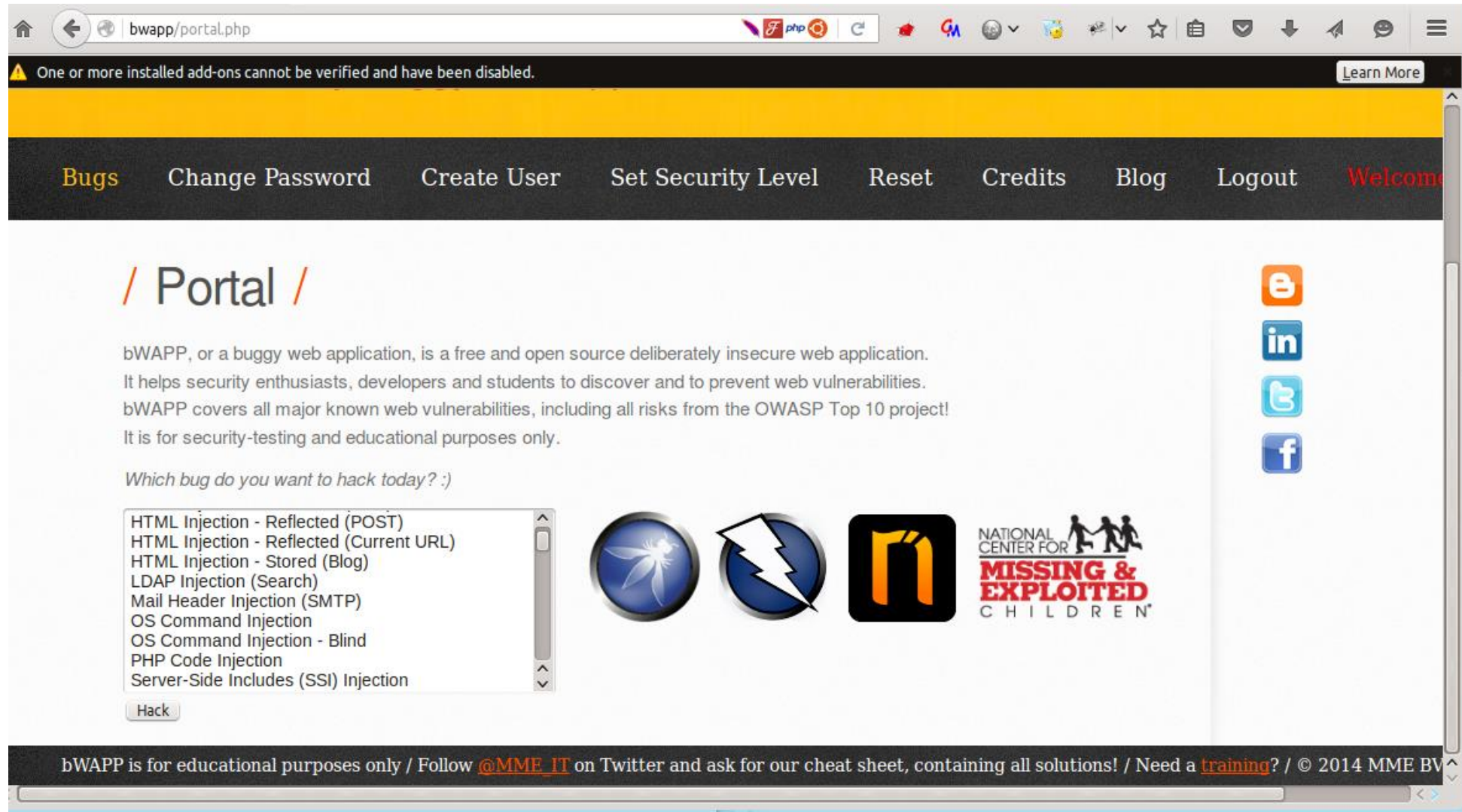
Created by fae frey
from Noun Project

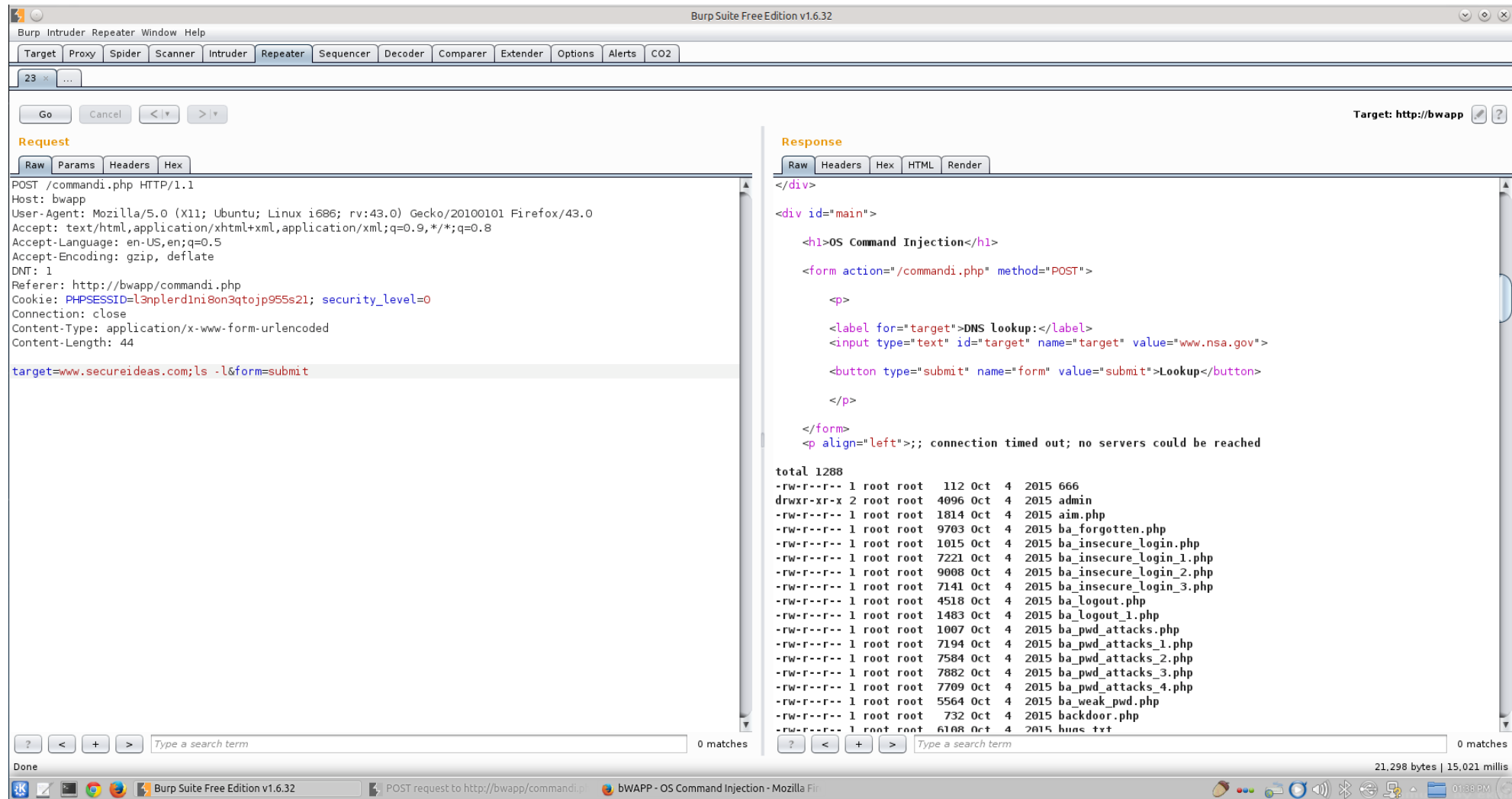
- Burp Repeater has various options that control its behavior, including-







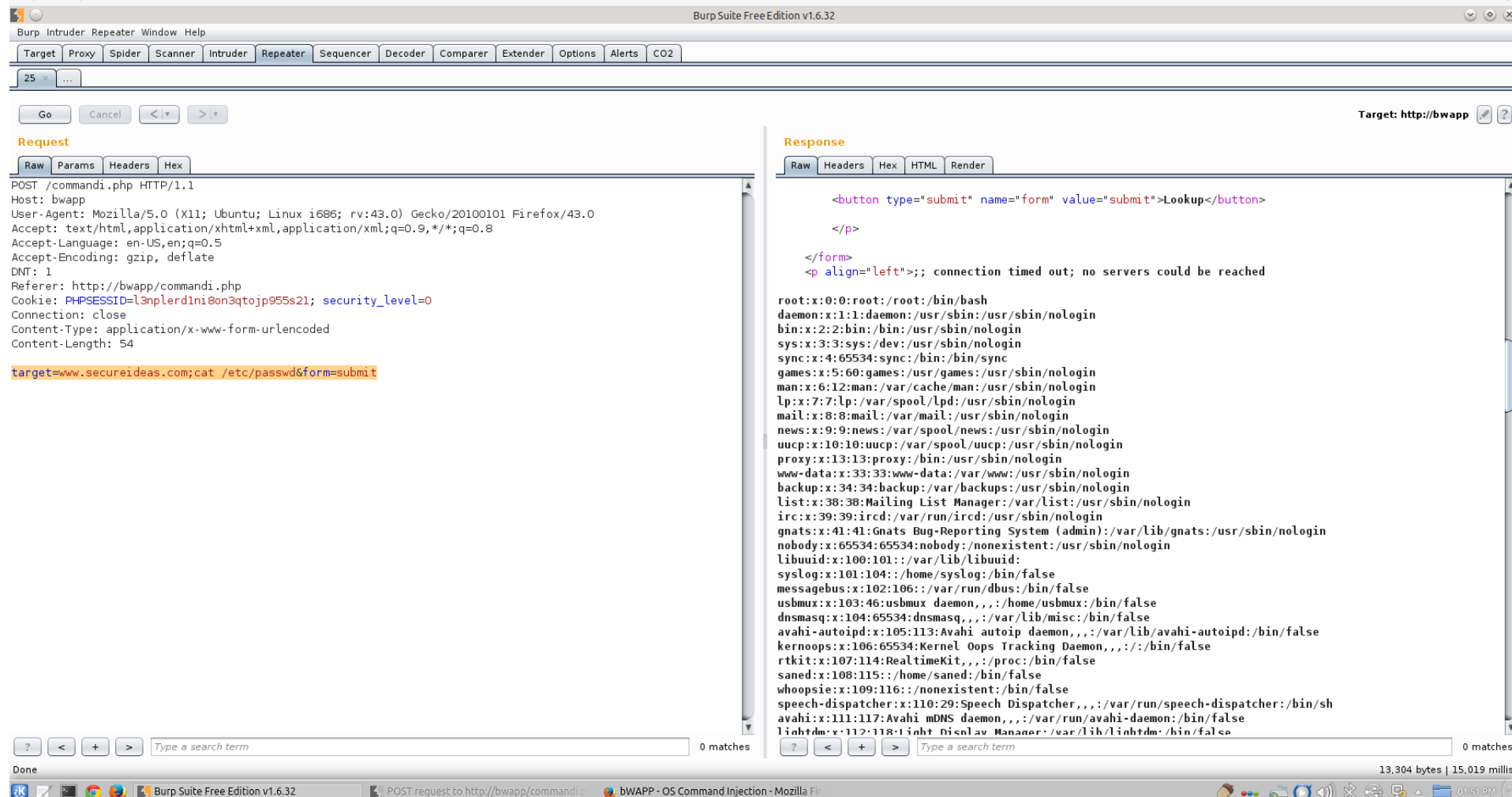




The screenshot displays the Burp Suite Free Edition v1.6.32 interface. The 'Repeater' tab is active, showing a list of requests. The selected request is a POST to `/commandi.php` with a target of `http://bwapp`. The request body contains a command injection payload: `target=www.secureideas.com;ls -l&form=submit`.

The response is displayed in the right pane, showing an HTML page with a form titled "OS Command Injection". The form has a text input field with the value `www.nsa.gov` and a submit button labeled "Lookup". Below the form, a message states: `<p align="left">; connection timed out; no servers could be reached`.

The bottom status bar indicates the response size is 21,298 bytes and the processing time is 15.021 milliseconds.



Name of the Activity

Behind the Door Number

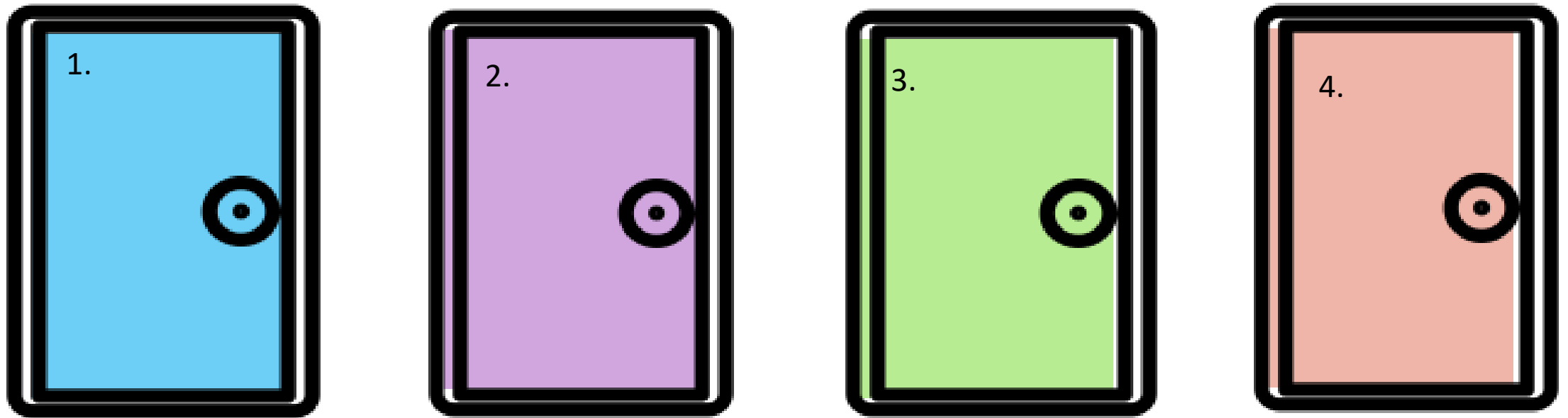
Instructions

Mode: **In-session**

Duration: **5 minutes**

Materials Required: **None**





What is Burp Intruder?

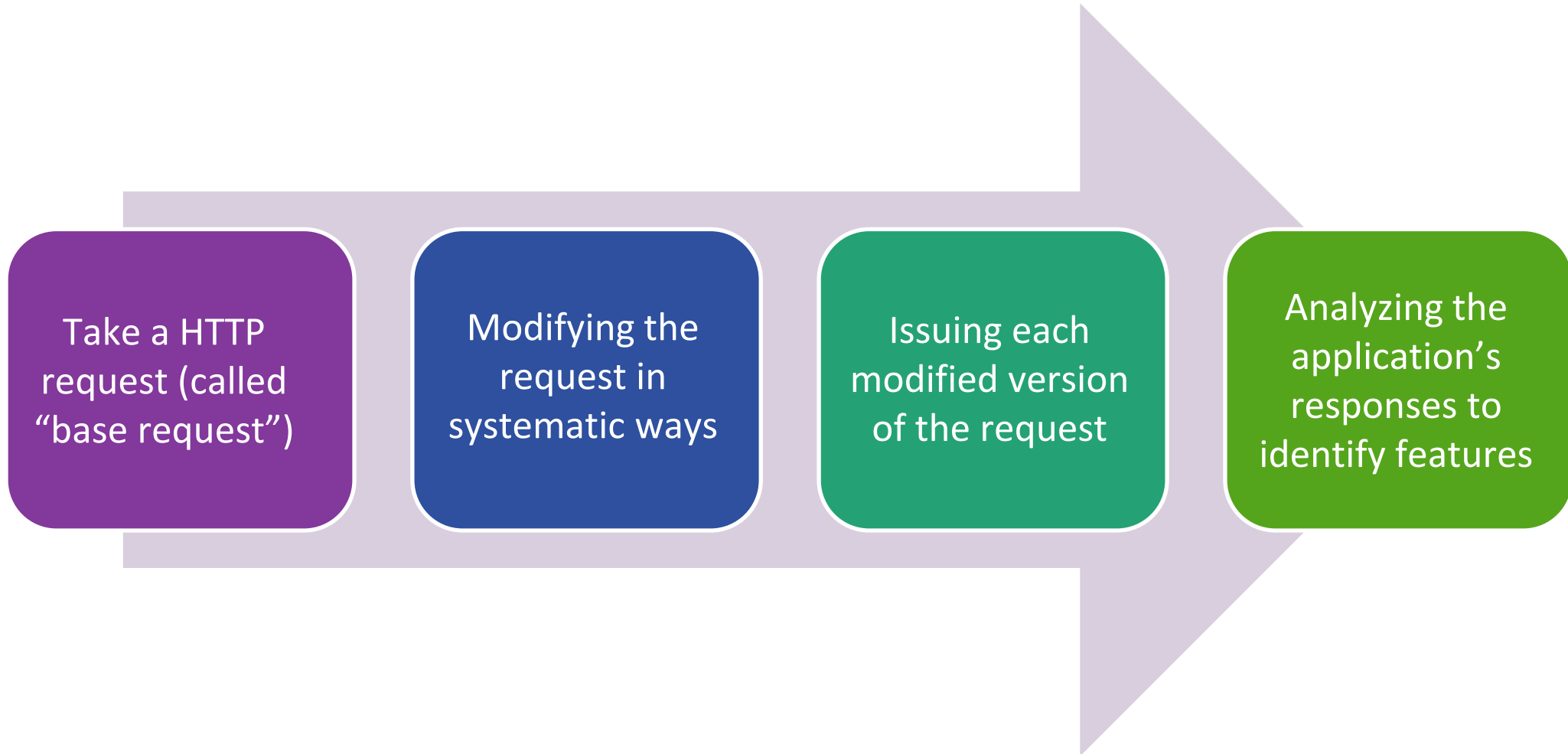


Created by fae frey
from Noun Project

- Burp Intruder is a tool for automating customized attacks against web applications
- It is extremely powerful and configurable
- It can be used to perform a huge range of tasks
- From simple brute-force guessing of web directories through to active exploitation of complex blind SQL injection vulnerabilities



Created by fae frey
from Noun Project



Name of the Activity

Complete the Image

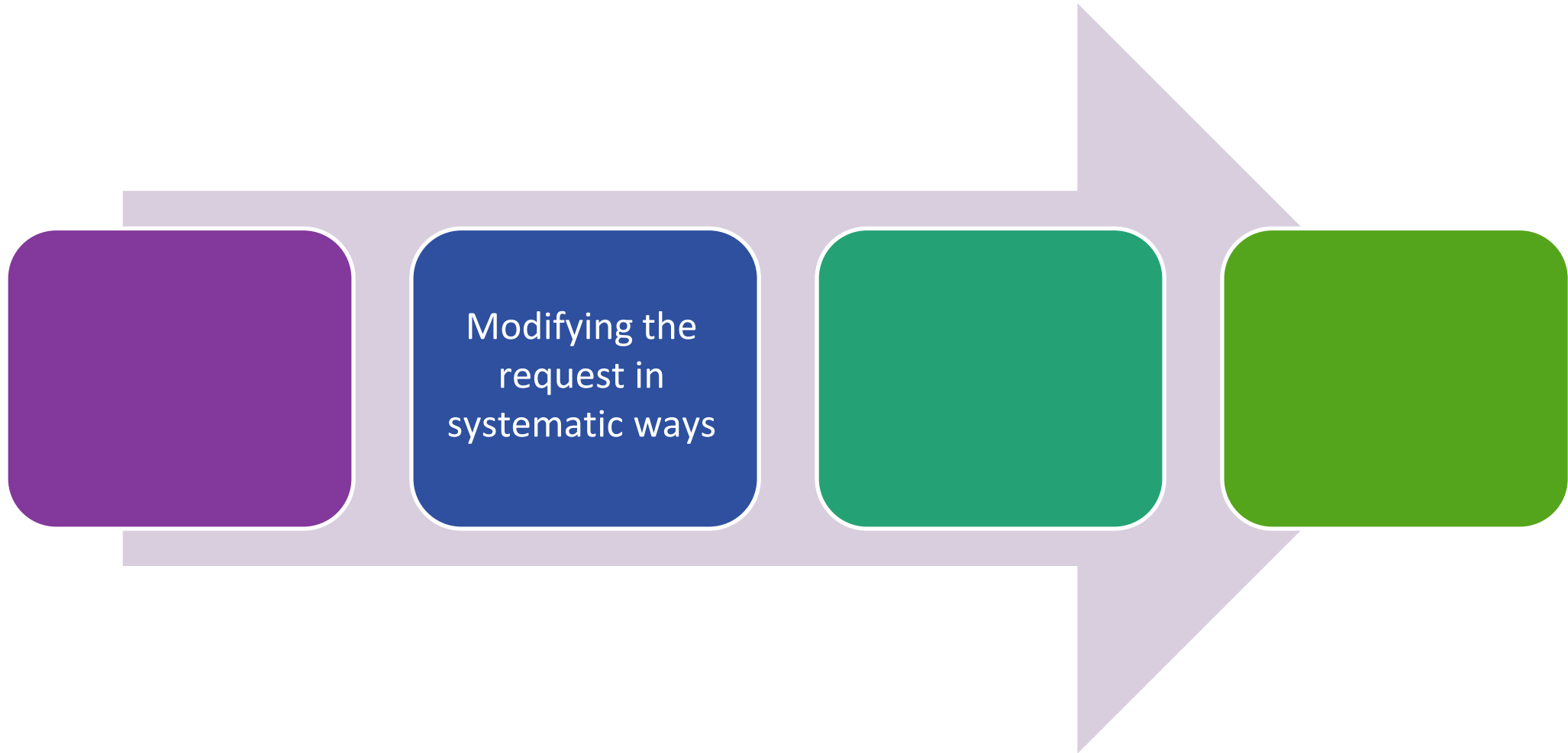
Instructions

Mode: **In-session**

Duration: **5 minutes**

Materials Required: **None**





- Burp Intruder is a very flexible tool
- It can help automate all kinds of tasks when testing web applications
- The most common use cases for Intruder fall into the following categories:

Enumerating Identifiers

Harvesting Useful Data

Fuzzing for Vulnerabilities



Created by fae frey
from Noun Project

Dashboard

Target

Proxy

Intruder

Repeater

Sequencer

Decoder

Comparer

Extender

Project options

User options

1 ×

2 ×

...

Target

Positions

Payloads

Options

?

Payload Positions

Start attack

Configure the positions where payloads will be inserted into the base request. The attack type determines the way in which payloads are assigned to payload positions - see help for full details.

Attack type:

1 GET /product?productId=\$6\$ HTTP/1.1

2 Host: ac2d1fac1e7d09d480ce541c00db00f4.web-security-academy.net

3 Connection: close

4 Upgrade-Insecure-Requests: 1

5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/87.0.4280.88 Safari/537.36

6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

7 Sec-Fetch-Site: same-origin

8 Sec-Fetch-Mode: navigate

9 Sec-Fetch-User: ?1

10 Sec-Fetch-Dest: document

11 Referer: https://ac2d1fac1e7d09d480ce541c00db00f4.web-security-academy.net/

12 Accept-Encoding: gzip, deflate

13 Accept-Language: en-GB,en-US;q=0.9,en;q=0.8

Add \$

Clear \$

Auto \$

Refresh



TATA TRUSTS

29

Dashboard

Target

Proxy

Intruder

Repeater

Sequencer

Decoder

Comparer

Extender

Project options

User options

1 ×

2 ×

...

Target

Positions

Payloads

Options

?

Payload Sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set:

1

▼

Payload count:

0

Payload type:

Username generator

▼

Request count:

0

?

Payload Options [Username generator]

This payload type lets you configure a list of names or email addresses, and derives potential usernames from these using various common schemes. You can enter items as "firstname lastname" or "firstname.lastname@example.org".

Maximum payloads per item:

50

Items

Paste

Load ...

Remove

Clear

Add

Enter a new item

Results	Target	Positions	Payloads	Options		
Filter: Showing all items						
Request	Payload	Status	Error	Timeout	Length ▾	Comment
26	adam	200	☐	☐	3186	
0		200	☐	☐	3184	
1	root	200	☐	☐	3184	
2	admin	200	☐	☐	3184	
3	test	200	☐	☐	3184	
4	guest	200	☐	☐	3184	
5	info	200	☐	☐	3184	
6	adm	200	☐	☐	3184	
7	mysql	200	☐	☐	3184	
8	user	200	☐	☐	3184	
9	administrator	200	☐	☐	3184	
10	oracle	200	☐	☐	3184	
11	ftp	200	☐	☐	3184	
12		200	☐	☐	3184	

1 x

2 x

...

Target

Positions

Payloads

Options

?

Payload Sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set:

1

Payload count:

5,200 (approx)

Payload type:

Username generator

Request count:

5,200 (approx)

?

Payload Options [Username generator]

This payload type lets you configure a list of names or email addresses, and derives potential usernames from these using various common schemes. You can enter items as "firstname lastname" or "firstname.lastname@example.org".

Maximum payloads per item:

50

Items (104)

Paste

Load ...

Remove

Clear

Add

root

admin

test

guest

info

adm

mysql

user

Enter a new item

1 x

2 x

...

Target

Positions

Payloads

Options

?

Payload Sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set:

1

Payload count:

1

Payload type:

Custom iterator

Request count:

1

?

Payload Options [Custom iterator]

This payload type lets you configure multiple lists of items, and generate payloads using all permutations of items in the lists.

Position:

1

Clear all

List items for position 1 (1)

Paste

AB/12

Load ...

Remove

Clear

Add

Add from list ...

Repeater	Sequencer	Decoder	Comparer	Extender	Project options	User options
Dashboard		Target		Proxy	Intruder	
1 x	2 x	...				
Target	Positions	Payloads	Options			

? **Payload Sets** Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set: Payload count: 8

Payload type: Request count: 0

? **Payload Options [Bit flipper]**

This payload type operates on an input and modifies the value of each bit position in turn. It can sometimes be used to meaningfully modify the decrypted values of CBC-encrypted data, and potentially interfere with application logic.

Operate on: ☐ Base value of payload position ☒ Specific string:

Format of original data: ☐ Literal value ☒ Encoded as ASCII hex

Select bits to flip:

☒ 1 (LSB)	☒ 3	☒ 5	☒ 7
☒ 2	☒ 4	☒ 6	☒ 8 (MSB)

Name of the Activity

Fastest Finger First

Instructions

Mode: **In-session**

Duration: **5 minutes**

Materials Required: **None**



Explain
Enumerating
Identifiers



Dashboard

Target

Proxy

Intruder

Repeater

Sequencer

Decoder

Comparer

Extender

Project options

User options

1 x

2 x

...

Target

Positions

Payloads

Options

?

Payload Positions

Start attack

Configure the positions where payloads will be inserted into the base request. The attack type determines the way in which payloads are assigned to payload positions - see help for full details.

Attack type:

Sniper

1 GET /product?product:Id=\$6\$ HTTP/1.1

2 Host: ac2dlfac1e7d09d480ce541c00db00f4.web-security-academy.net

3 Connection: close

4 Upgrade-Insecure-Requests: 1

5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/87.0.4280.88 Safari/537.36

6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

7 Sec-Fetch-Site: same-origin

8 Sec-Fetch-Mode: navigate

9 Sec-Fetch-User: ?1

10 Sec-Fetch-Dest: document

11 Referer: https://ac2dlfac1e7d09d480ce541c00db00f4.web-security-academy.net/

12 Accept-Encoding: gzip, deflate

13 Accept-Language: en-GB,en-US;q=0.9,en;q=0.8

Add \$

Clear \$

Auto \$

Refresh

1 x

2 x

...

Target

Positions

Payloads

Options

?

Payload Sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set:

1

▼

Payload count:

0

Payload type:

Numbers

▼

Request count:

0

?

Payload Options [Numbers]

This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type:

☒ Sequential

☐ Random

From:

To:

Step:

How many:

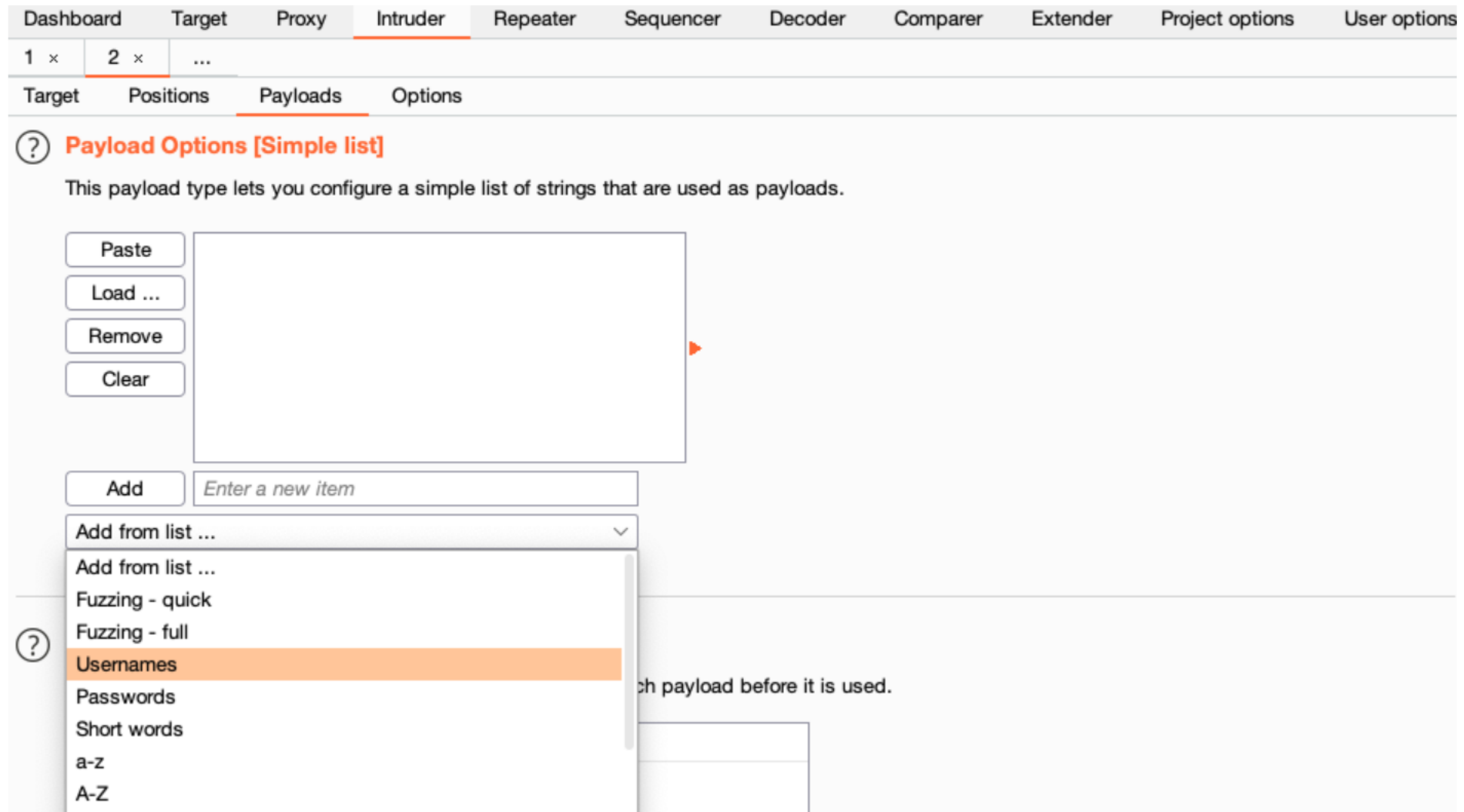
? Grep - Extract

↻ These settings can be used to extract useful information from responses into the attack results table.

☒ Extract the following items from responses:

Add	From [ProductID], length 10
Edit	
Remove	
Duplicate	
Up	
Down	
Clear	

Maximum capture length:



The screenshot shows the Burp Suite Intruder tool interface. The top navigation bar includes tabs for Dashboard, Target, Proxy, Intruder (selected), Repeater, Sequencer, Decoder, Comparer, Extender, Project options, and User options. Below this, there are sub-tabs for Target, Positions, Payloads (selected), and Options. The main area is titled "Payload Options [Simple list]" with a help icon. A description states: "This payload type lets you configure a simple list of strings that are used as payloads." On the left, there are four buttons: Paste, Load ..., Remove, and Clear. In the center is a large empty text box. Below this, there is an "Add" button and a text input field with the placeholder "Enter a new item". A dropdown menu is open, showing options: "Add from list ..." (selected), "Add from list ...", "Fuzzing - quick", "Fuzzing - full", "Usernames" (highlighted in orange), "Passwords", "Short words", "a-z", and "A-Z". A help icon is also visible next to the dropdown. At the bottom right, there is a partially visible text box with the text "ch payload before it is used."

DashboardTargetProxyIntruderRepeaterSequencerDecoderComparerExtenderProject optionsUser options

1 x2 x...

TargetPositionsPayloadsOptions

?

Payload Positions

Start attack

Configure the positions where payloads will be inserted into the base request. The attack type determines the way in which payloads are assigned to payload positions - see help for full details.

Attack type:

```
1 GET /product?productId=$8913375977302166783$ HTTP/1.1
2 Host: ac901f6f1f068a6780b55af300e200fd.web-security-academy.net
3 Connection: close
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/87.0.4280.88 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.
  8,application/signed-exchange;v=b3;q=0.9
7 Sec-Fetch-Site: same-origin
8 Sec-Fetch-Mode: navigate
9 Sec-Fetch-User: ?1
10 Sec-Fetch-Dest: document
11 Referer: https://ac901f6f1f068a6780b55af300e200fd.web-security-academy.net/
12 Accept-Encoding: gzip, deflate
```

Add \$

Clear \$

Auto \$

Refresh

Dashboard

Target

Proxy

Intruder

Repeater

Sequencer

Decoder

Comparer

Extender

Project options

User options

1 ×

2 ×

...

Target

Positions

Payloads

Options

?

Payload Sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set:

1

Payload count:

0

Payload type:

Simple list

Request count:

0

?

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load ...

Remove

Clear

Look In:

Lists

extracted-list.txt

Name of the Activity

Fastest Finger First

Instructions

Mode: **In-session**

Duration: **5 minutes**

Materials Required: **None**



Explain Harvesting Useful Data



DashboardTargetProxyIntruderRepeaterSequencerDecoderComparerExtenderProject optionsUser options

1 × ...

TargetPositionsPayloadsOptions

?

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load ...

Remove

Clear

Enter a new item

Add from list ...

Add from list ...

Fuzzing - quick

Fuzzing - full

Username

Passwords

Short words

'

'_

' or 1=1--

1 or 1=1--

' or 1 in (@@version)--

1 or 1 in (@@version)--

'; waitfor delay '0:30:0'--

1; waitfor delay '0:30:0'--

ch payload before it is used.

Results	Target	Positions	Payloads	Options			
Filter: Showing all items							
Request	Payload		Status	Error	Timeout	Length ▾	Comment
6	adm		200	☐	☐	3186	
0			200	☐	☐	3184	
1	root		200	☐	☐	3184	
2	admin		200	☐	☐	3184	
3	test		200	☐	☐	3184	
4	guest		200	☐	☐	3184	
5	info		200	☐	☐	3184	
7	mysql		200	☐	☐	3184	
8	user		200	☐	☐	3184	
9	administrator		200	☐	☐	3184	
10	oracle		200	☐	☐	3184	
11	ftp		200	☐	☐	3184	
12	pi		200	☐	☐	3184	

Name of the Activity

Fastest Finger First

Instructions

Mode: **In-session**

Duration: **5 minutes**

Materials Required: **None**



Explain Fuzzing for Vulnerabilities



What is Burp Decoder?



Created by fae frey
from Noun Project

- Burp Decoder is a simple tool for transforming encoded data into its canonical form
- It is for transforming raw data into various encoded and hashed forms
- It is capable of intelligently recognizing several encoding formats using heuristic techniques



Created by fae frey
from Noun Project

- You can load data into Decoder in two ways:

Type or paste it directly into the top editor panel

Select data anywhere within Burp, and choose "Send to Decoder" from the context menu

- You can use the "Text" and "Hex" buttons to toggle the type of editor to use on your data



Created by fae frey
from Noun Project

- When a part of the data has a transformation applied, the following things happen:

The part of the data to be transformed is colored accordingly

A new editor is opened showing the results of all the applied transformations

- The new editor enables you to work recursively, applying multiple layers of transformations to the same data



Created by fae frey
from Noun Project

- To perform manual decoding and encoding
- Use the drop-down lists to select the required transformation
- The chosen transformation will be applied to the selected data
- To the whole data if nothing is selected



Created by fae frey
from Noun Project

- On any panel within Decoder, you can click the "Smart Decode" button
- Burp will then attempt to intelligently decode the contents of that panel by looking for data
- This action is performed recursively
- This option can be a useful first step when you have identified some opaque data
- You can see the stages involved in the decoding, and the transformation that was applied at each position.



Created by fae frey
from Noun Project

Name of the Activity

Correct or Incorrect

Instructions

Mode: **In-session**

Duration: **5 minutes**

Materials Required: **None**





1. Burp Intruder is a simple tool for transforming encoded data into its canonical form or for transforming raw data into various encoded and hashed forms. 
2. You can use the "Text" and "Hex" buttons to toggle the type of editor to use on your data 
3. Because Burp Decoder makes a "best guess" attempt to recognize some common encoding formats, it will sometimes make mistakes. 
4. Burp Repeater is capable of intelligently recognizing several encoding formats using heuristic techniques. 

What is Burp Comparer?



Created by fae frey
from Noun Project

- Burp Comparer is a simple tool for performing a comparison (a visual "diff") between any two items of data
- Some common uses for Burp Comparer are as follows:

When looking for username enumeration conditions, compare responses to failed logins using valid and invalid usernames

When an Intruder attack has, you can compare these to quickly see where the differences lie

When comparing the site maps or Proxy history entries generated by different types of users, you can compare pairs of similar requests to see where the differences lie

When testing for blind SQL injection bugs using Boolean condition injection, you can compare two responses to see whether injecting different conditions has

You can load data into Comparer in the following ways:

Paste it directly from the clipboard.

Load it from file.

Select data anywhere within Burp, and choose "Send to Comparer" from the context menu.



Created by fae frey
from Noun Project

Each item of loaded data is shown in two identical lists. To perform a comparison, select a different item from each list and click one of the "Compare" buttons:

Word Compare

- This comparison tokenizes each item of data based on whitespace delimiters and the token-level edits required to transform the first item into the second
- It is most useful when the interesting differences between the compared items exist at the word level

Byte Compare

- This comparison identifies the byte-level edits required to transform the first item into the second
- It is most useful when the interesting differences between the compared items exist at the byte level

Name of the Activity

Taboo

Instructions

Mode: **In-session**

Duration: **5 minutes**

Materials Required: **None**



He Who Asks a Question

May Remain a Fool
For Five Minutes

But, He Who
Does Not Ask
Remains a Fool
Forever



Source: Freepik

In this session, you learnt about:

- Burp Suite Repeater
- Burp Suite Intruder
- Burp Suite Decoder
- Burp Suite Comparer



In this topic, you will further learn about:

- Bug Bounty Programmes
- HackerOne
- BugCrowd
- Certifications
- CEH
- OSCP



Source: Pixabay



*Skill Development Initiative of Tata
Trusts*

- www.tatastrive.com -